

Riverbend Boutique - STRIDE Threat Model

Task 3: System architecture, STRIDE threats and risk ranking

1. System Architecture

CLIENT	→	NGINX WEB SERVER	→	PHP APPLICATION	→	MARIADB DATABASE
Browser/User	HTTP	Web Server	FastCGI	Application	SQL	riverbend_shop

External Services are connected to the PHP Application for external requests and responses. The lab/application boundary contains the web server, PHP application and MariaDB database.

2. STRIDE Threat Categories

S = Spoofing **T** = Tampering **R** = Repudiation **I** = Information Disclosure **D** = Denial of Service **E** = Elevation of Privilege

Risk Score = Likelihood × Impact. Both Likelihood and Impact use a 1–5 scale.

Component	Threat	Likelihood	Impact	Score
PHP Application	SQL injection-like input modifies application behaviour	4	5	20
NGINX Web Server	Malicious HTTP parameters or paths are submitted	4	4	16
NGINX Web Server	Excessive HTTP requests exhaust web-server resources	4	4	16
Client	Client attempts to access administrative functionality	3	5	15
NGINX Web Server	Attacker attempts to reach restricted administrative paths	3	5	15
PHP Application	Application exposes sensitive data through responses	3	5	15
PHP Application	Attacker attempts to access administrative functionality	3	5	15
MariaDB Database	Unauthorized actor attempts to authenticate as a database user	3	5	15
MariaDB Database	Unauthorized SQL modifies stored product data	3	5	15
MariaDB Database	Unauthorized database queries expose stored information	3	5	15
MariaDB Database	Excessive database queries consume database resources	3	5	15
External Services	Data exchanged with an external service is modified	3	5	15
External Services	Sensitive application data is exposed to an external service	3	5	15
Client	Attacker impersonates a legitimate client or user	3	4	12
Client	Malicious client modifies request parameters	4	3	12
Client	Client sends excessive requests to consume resources	3	4	12
NGINX Web Server	Attacker spoofs a trusted request source	3	4	12
NGINX Web Server	Error or configuration information is exposed	3	4	12
PHP Application	Attacker impersonates an application user	3	4	12
PHP Application	Malicious requests consume PHP-FPM resources	3	4	12
External Services	External service becomes unavailable	3	4	12

Component	Threat	Likelihood	Impact	Score
MariaDB Database	Database user gains unauthorized administrative privileges	2	5	10
External Services	Attacker impersonates an external service	2	5	10
External Services	Compromised integration credentials provide unauthorized access	2	5	10
Client	Sensitive information is exposed through client responses	3	3	9
MariaDB Database	Database activity cannot be attributed to a specific actor	2	4	8
External Services	External transaction or request cannot be reliably traced	2	4	8
Client	User denies sending a malicious request	2	3	6
NGINX Web Server	Request activity is disputed or insufficiently logged	2	3	6
PHP Application	Application actions cannot be linked to a verified user	2	3	6

3. Observed Security Findings

- SQL injection-like request observed in the NGINX access log.
- /admin path probing was observed.
- /wp-login.php probing was observed.
- /etc/passwd probing was observed.

4. Risk Methodology

Likelihood and Impact are rated from 1 to 5. The risk score is calculated as $\text{Likelihood} \times \text{Impact}$. The risk-ranking CSV is sorted from the highest score to the lowest score.

5. Scope and Limitations

This threat model is based on the Riverbend Boutique lab architecture and the observed log-analysis findings. It represents a simplified lab environment and does not claim to cover every possible production threat.